

Mise en garde Microsoft

Le 02/03/2026 Microsoft a fait une communication sur des campagnes de phishing et OAuth. Cette campagne cible les organisations gouvernementales mais concerne aussi les entreprises utilisant Microsoft Entra ID.

Qu'est-ce qu'une campagne par OAuth ?

C'est une méthode de redirection d'URL grâce à des liens d'hameçonnage afin de contourner les mécanismes de défense actuel. Concrètement une personne en cliquant sur lien qui semble être un document Excel ou un lien pour rejoindre une réunion Teams est en fait une page factice pour récupérer des données d'entreprises. Parfois ces URL sont camouflées dans des PDF.

Initialement OAuth est une application qui utilise le protocole OAuth 2.0. Cette application est hébergée chez un fournisseur d'identité comme Microsoft Entra ID mais il en existe d'autre. Ces malfaiteurs créent une application ayant pour objectif de falsifier une connexion à l'infrastructure de la cible. Dans certains cas cela mène à l'installation automatique d'un virus sur le poste à la suite d'une erreur de connexion en téléchargeant un .zip avec des commandes PowerShell.

Microsoft suggère aux entreprises de renforcer la sécurité des autorisations OAuth en protégeant contre les redirections d'erreurs à l'authentification et de renforcer les méthodes d'authentification. Cette faille, n'est pas logicielle mais concerne une conception banale qui est utilisée quotidiennement dans beaucoup d'entreprise.

Sources :

<https://www.bleepingcomputer.com/news/security/microsoft-hackers-abuse-oauth-error-flows-to-spread-malware/>

<https://thehackernews.com/2026/03/microsoft-warns-oauth-redirect-abuse.html>